AWS CloudHSM Security

ENCRYPTION

AWS CloudHSM provides single-tenant, FIPS-validated hardware security modules in your VPC for cryptographic key generation, storage, and operations. The primary attack surface centers on HSM user credential compromise, network-level access to HSM ENIs, and IAM-level control-plane abuse that can destroy clusters or exfiltrate backups.

HIGH	Regional	FIPS 140-3 L3	Dedicated
Risk Level	Scope	Key Feature	Management

📋 Service Overview

HSM Clusters & Instances

CloudHSM clusters contain one or more HSM instances distributed across Availability Zones within a VPC. Each HSM gets an Elastic Network Interface (ENI) in your subnet. Clients connect via ports 2223-2225.

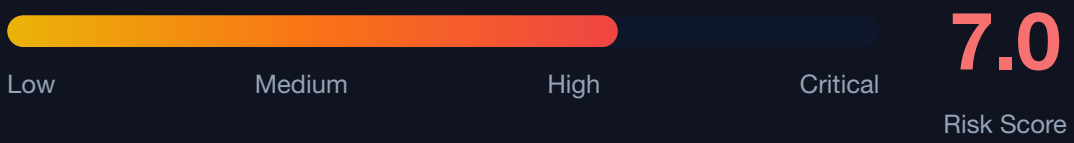
Attack note: Compromising the cluster security group or gaining network access to the HSM ENIs allows direct interaction with HSM instances. Overly permissive security groups are the most common network-level misconfiguration.

HSM User Model (Admin / CU / AU)

CloudHSM has its own user model separate from IAM. Three user types: Admin (manages users), Crypto User (creates/uses keys), and Appliance User (AWS-managed sync). The default admin account is named "admin".

Attack note: HSM user credentials are managed outside of IAM -- if an attacker obtains the admin or CU password, IAM policies cannot prevent HSM-level operations. Credential theft is the highest-impact vector.

Security Risk Assessment



7.0

Risk Score

CloudHSM has strong cryptographic protections -- key material never leaves the HSM unencrypted. However, risk is HIGH because HSM user credentials exist outside IAM, the IAM control plane allows cluster destruction and backup exfiltration, and quorum authentication is not enabled by default.

⚔️ Attack Vectors

Credential & Authentication Attacks

- HSM admin credential theft from configs/env vars
- Crypto User password compromise for key operations
- Weak admin password (no complexity enforced)
- kmsuser credential extraction from custom key store
- Brute-force HSM login (lockout after 5 attempts)

IAM Control-Plane Attacks

- Cluster deletion via DeleteCluster/DeleteHsm
- Backup exfiltration via CopyBackupToRegion
- Backup deletion via DeleteBackup
- HSM addition to attacker subnet via CreateHsm
- Resource policy manipulation via PutResourcePolicy

⚠️ Misconfigurations

Cluster & Network

- Single-AZ deployment (no high availability)
- Overly permissive security group on HSM ENIs
- HSM in public subnet instead of private
- Modified cluster security group TCP rules
- No VPC Flow Logs on HSM subnets

User & Key Management

- Quorum authentication not enabled
- HSM credentials stored in plaintext
- No key sharing restrictions between CUs
- HSM user passwords not rotated
- Wildcard IAM policies (cloudhsm:*)

🔍 Enumeration

List All CloudHSM Clusters

```
aws cloudhsmv2 describe-clusters
```

Describe a Specific Cluster

```
aws cloudhsmv2 describe-clusters \
  --filters clusterIds=cluster-1234abcd5678
```

List All Backups

```
aws cloudhsmv2 describe-backups
```

List Tags on a Cluster

```
aws cloudhsmv2 list-tags \
  --resource-id cluster-1234abcd5678
```

Get Resource Policy on a Backup

```
aws cloudhsmv2 get-resource-policy \
  --resource-arn arn:aws:cloudhsm:us-east-1:123456789012:backup/backup-1234abcd5678
```

📈 Privilege Escalation

IAM-Level Escalation

- CreateCluster + CreateHsm + InitializeCluster from stolen backup
- RestoreBackup + CreateCluster to recover key material
- PutResourcePolicy for cross-account backup access
- CopyBackupToRegion to region with more permissive IAM

HSM-Level Escalation

- Admin resets CU password to access their keys
- CU key sharing abuse for lateral access

Key insight: Attacker still needs HSM user credentials to log in and use keys. Backups are encrypted and can only be restored to AWS-owned HSMs.

🔗 Persistence

Backup-Based Persistence

- Copy backups to attacker-controlled region
- Restore backups to new cluster with known credentials
- Create additional HSM in attacker-accessible subnet
- PutResourcePolicy granting cross-account access
- Maintain HSM user credentials for persistent access

Destruction Scenarios

- Delete all backups to prevent recovery
- Delete HSMs and cluster for denial of service
- Disconnect KMS custom key store
- Reset admin password to lock out legitimate users

🛡️ Detection

CloudTrail Events

- DeleteCluster / DeleteHsm - cluster destruction
- DeleteBackup - backup removal
- CopyBackupToRegion - backup exfiltration
- PutResourcePolicy - cross-account access granted
- CreateHsm - new HSM added

HSM Audit Logs (CloudWatch)

- Failed login attempts to HSM user accounts
- User creation/deletion operations
- Key export operations
- Password change events
- Quorum authentication changes

💻 Exploitation Commands

Copy Backup to Attacker Region

```
aws cloudhsmv2 copy-backup-to-region \
  --destination-region eu-west-1 \
  --backup-id backup-1234abcd5678
```

Create New Cluster from Stolen Backup

```
aws cloudhsmv2 create-cluster \
  --hsm-type hsm2m.medium \
  --subnet-ids subnet-abcdef12 \
  --source-backup-id backup-1234abcd5678
```

Add HSM to New Cluster

```
aws cloudhsmv2 create-hsm \
  --cluster-id cluster-newcluster \
  --availability-zone eu-west-1a
```

Delete Backup (Destruction)

```
aws cloudhsmv2 delete-backup \
  --backup-id backup-1234abcd5678
```

Delete HSM from Cluster

```
aws cloudhsmv2 delete-hsm \
  --cluster-id cluster-1234abcd5678 \
  --hsm-id hsm-abcdef123456
```

List Backups for Exfiltration

```
aws cloudhsmv2 describe-backups \
  --query "Backups[*].
{ID:BackupId,ClusterId:ClusterId,State:BackupState}"
```

📜 Policy Examples

✗ Dangerous - Full CloudHSM Access

```
{
  "Effect": "Allow",
  "Action": "cloudhsm:*",
  "Resource": "*"
}
```

Grants full control including DeleteCluster, DeleteHsm, DeleteBackup, CopyBackupToRegion, and PutResourcePolicy

✓ Secure - Read-Only Monitoring

```
{
  "Effect": "Allow",
  "Action": [
    "cloudhsm:DescribeClusters",
    "cloudhsm:DescribeBackups",
    "cloudhsm:ListTags"
  ],
  "Resource": "*"
}
```

Read-only access for monitoring and inventory. Cannot modify, delete, or create resources.

✓ Secure - Operator (No Delete, No Export)

```
{
  "Effect": "Deny",
  "Action": [
    "cloudhsm:DeleteCluster",
    "cloudhsm:DeleteHsm",
    "cloudhsm:DeleteBackup",
    "cloudhsm:CopyBackupToRegion",
    "cloudhsm:PutResourcePolicy"
  ],
  "Resource": "*"
}
```

Explicitly denies destructive actions and exfiltration vectors

Defense Recommendations

Enable Quorum Authentication (M-of-N)

Require multiple admins to approve sensitive operations like user creation, deletion, and password changes.

Deploy Multi-AZ Clusters

Always run at least two HSMs in separate Availability Zones for high availability.

```
aws cloudhsmv2 create-hsm --cluster-id
cluster-1234abcd5678 --availability-zone us-east-1b
```

Restrict CloudHSM Security Group

Ensure the cluster security group only allows inbound traffic from authorized client instances.

```
aws ec2 describe-security-groups --group-ids sg-
cloudhsmclustersg --query
"SecurityGroups[*].IpPermissions"
```

Enable CloudTrail + HSM Audit Logs

Monitor all CloudHSM API calls via CloudTrail and HSM-level audit logs via CloudWatch Logs.

```
aws logs describe-log-groups --log-group-name-prefix /
aws/cloudhsm
```

Secure HSM Credentials

Store HSM user credentials in AWS Secrets Manager with automatic rotation. Never store in plaintext.

Apply SCPs to Prevent Destruction

Use Service Control Policies to prevent unauthorized deletion of CloudHSM resources.

```
"Effect": "Deny", "Action": ["cloudhsm:DeleteCluster",
"cloudhsm:DeleteHsm", "cloudhsm:DeleteBackup"]
```


Always obtain proper authorization before testing